

DANH SÁCH ĐỀ TÀI BTL AN TOÀN ỨNG DỤNG WEB VÀ CSDL

Mã đề tài	Tên đề tài	Yêu cầu
1	Tìm hiểu về mật khẩu sử dụng một lần OTP	Tìm hiểu các phương pháp sinh và chuyển giao OTP. Phân tích các rủi ro liên quan. Xây dựng một trang web đơn giản có chức năng sinh, gửi và xác thực OTP. Thực nghiệm một số kịch bản tấn công phù hợp trong môi trường mô phỏng và triển khai các biện pháp bảo vệ. Demo hệ thống trước và sau khi áp dụng giải pháp bảo mật.
2	Tìm hiểu và triển khai tường lửa ứng dụng web (Web Application Firewall).	Tìm hiểu về kiến trúc, hoạt động, cách thức tạo luật và cài đặt tường lửa ứng dụng web ModSecurity. Xây dựng website có các điểm yếu XSS và SQL Injection trong môi trường giả lập; triển khai ModSecurity để phát hiện/chặn các cuộc tấn công; demo và đánh giá hiệu quả trước và sau khi áp dụng ModSecurity.
3	Tìm hiểu về hệ quản trị CSDL MySQL	Kiến trúc, các thành phần, tính năng và các cơ chế bảo mật của MySQL. Xây dựng một website đơn giản kết nối với database trong MySQL; thực nghiệm một số demo tấn công và triển khai các cơ chế bảo mật của MySQL để khắc phục. Demo đánh giá hiệu quả trước và sau khi áp dụng giải pháp
4	Tìm hiểu và thực nghiệm Brute-force và Credential Stuffing. Các giải pháp phòng thủ.	Xây dựng một website có chức năng đăng nhập; mô phỏng tấn công; triển khai các giải pháp bảo mật như Rate Limiting, CAPTCHA và Account Lockout.
5	Tìm hiểu về hệ quản trị CSDL Microsoft SQL Server	Kiến trúc, các thành phần, tính năng và các cơ chế bảo mật của SQL Server. Xây dựng một website đơn giản kết nối với database trong SQL Server; thực nghiệm một số demo tấn công và triển khai các cơ chế bảo mật của SQL Server để khắc phục. Demo đánh giá hiệu quả trước và sau khi áp dụng giải pháp
6	Tìm hiểu về CAPTCHAR và các phương pháp tạo CAPTCHAR trong ứng dụng Web	Tìm hiểu mục đích, nguyên lý hoạt động và các dạng CAPTCHA phổ biến. Phân tích khả năng chống bot và những hạn chế của CAPTCHA. Xây dựng website tích hợp CAPTCHA; thực nghiệm mô phỏng hành vi tự động/bot trong môi trường kiểm thử; triển khai các biện pháp tăng cường bảo vệ.
7	Tìm hiểu và triển khai chuỗi cân bằng tải các máy chủ Web (web server load balancing cluster).	Tìm hiểu kiến trúc, vai trò và các thuật toán cân bằng tải trong hệ thống Web Server Cluster. Xây dựng mô hình gồm 2–3 Web Server phục vụ cùng một website và một thành phần cân bằng tải. Thực nghiệm phân phối request, kiểm tra khả năng đáp ứng khi một server gặp sự cố.
8	Tìm hiểu về hệ quản trị Cơ sở dữ liệu MongoDB	Kiến trúc, các thành phần, tính năng và các cơ chế bảo mật của MongoDB. Xây dựng một website đơn giản kết nối với database trong MongoDB; thực nghiệm một số demo tấn công và triển khai các cơ chế bảo mật của MongoDB để khắc phục. Demo đánh giá hiệu quả trước và sau khi áp dụng giải pháp
9	Tìm hiểu về nền tảng xử lý song song Apache Spark.	Giới thiệu, kiến trúc, hoạt động. Cài đặt và thử nghiệm Apache Spark.

10	Tìm hiểu về hệ quản trị Cơ sở dữ liệu Oracle	Kiến trúc, các thành phần, tính năng và các cơ chế bảo mật của Oracle. Xây dựng một website đơn giản kết nối với database trong Oracle; thực nghiệm một số demo tấn công và triển khai các cơ chế bảo mật của Oracle để khắc phục. Demo đánh giá hiệu quả trước và sau khi áp dụng giải pháp
11	Tìm hiểu về hệ quản trị CSDL PostgreSQL	Kiến trúc, các thành phần, tính năng và các cơ chế bảo mật của PostgreSQL. Xây dựng một website đơn giản kết nối với database trong PostgreSQL; thực nghiệm một số demo tấn công và triển khai các cơ chế bảo mật của PostgreSQL để khắc phục. Demo đánh giá hiệu quả trước và sau khi áp dụng giải pháp
12	Tìm hiểu và so sánh các công cụ và phần mềm kiểm tra bảo mật cơ sở dữ liệu phổ biến như IBM Guardium, Imperva SecureSphere, McAfee Database Security	Cài đặt và chạy thử 1 công cụ (có thể dùng công cụ mã nguồn mở ngoài 3 công cụ gợi ý) và thực hiện quét, tạo báo cáo và phân tích lỗ hổng.
13	Tìm hiểu về lỗ hổng Directory Traversal. Giải pháp phòng chống	Tìm hiểu nguyên nhân gây ra lỗ hổng này, cách thức tin tặc khai thác tấn công; trình bày giải pháp (cách fix) lỗ hổng này. Có demo tấn công cũng như cách khắc phục trên hệ thống giả lập tự xây dựng.
14	Tìm hiểu về lỗ hổng Remote Code Execution. Giải pháp phòng chống	Tìm hiểu nguyên nhân gây ra lỗ hổng này, cách thức tin tặc khai thác tấn công; trình bày giải pháp (cách fix) lỗ hổng này. Có demo tấn công cũng như cách khắc phục trên hệ thống giả lập tự xây dựng.
15	Tìm hiểu về lỗ hổng File Inclusion trong ứng dụng web. Giải pháp phòng chống.	Tìm hiểu nguyên nhân gây ra lỗ hổng này, cách thức tin tặc khai thác tấn công; trình bày giải pháp (cách fix) lỗ hổng này. Có demo tấn công cũng như cách khắc phục trên hệ thống giả lập tự xây dựng.
16	Ứng dụng học máy trong phân tích log hệ thống để phát hiện tấn công web	Tìm hiểu đặc điểm của Web log và các phương pháp thu thập, tiền xử lý log. Nghiên cứu các kỹ thuật học máy có thể sử dụng để phát hiện các hành vi/tấn công Web. Thực nghiệm đánh giá mô hình học máy trên các dataset tiêu biểu
17	Xây dựng công cụ pentest tự động	Tìm hiểu quy trình và các kỹ thuật kiểm thử bảo mật Web. Thiết kế và xây dựng công cụ tự động kiểm thử ứng dụng Web.
18	Ứng dụng học máy trong phát hiện URL giả mạo	Tìm hiểu phishing và đặc điểm của URL giả mạo. Nghiên cứu các đặc trưng URL và phương pháp học máy dùng để phân loại URL. Thực nghiệm đánh giá mô hình học máy trên các dataset tiêu biểu
19	Áp dụng công nghệ blockchain trong bảo mật cơ sở dữ liệu	Tìm hiểu nguyên lý Blockchain và khả năng ứng dụng trong đảm bảo tính toàn vẹn, truy xuất nguồn gốc dữ liệu. Xây dựng mô hình thử nghiệm lưu vết hoặc xác thực tính toàn vẹn của dữ liệu CSDL bằng Blockchain. Thực nghiệm thay đổi dữ liệu trái phép và kiểm tra khả năng phát hiện; phân tích ưu điểm, hạn chế và chi phí của giải pháp so với phương pháp truyền thống.
20	Tìm hiểu và thực nghiệm XXE trong ứng dụng Web. Giải pháp phòng chống.	Tìm hiểu nguyên nhân gây ra lỗ hổng này, cách thức tin tặc khai thác tấn công; trình bày giải pháp (cách fix) lỗ hổng này. Có demo tấn công cũng như cách khắc phục trên hệ thống giả lập tự xây dựng.

21	Tìm hiểu và thực nghiệm Web Cache Poisoning. Giải pháp phòng chống	Tìm hiểu cơ chế Web Cache, Cache Key và nguyên lý Web Cache Poisoning. Xây dựng môi trường giả lập gồm Web Server và thành phần cache/reverse proxy; thực nghiệm một kịch bản cache poisoning an toàn trong môi trường lab; phân tích request, response, cache key và nguyên nhân lỗi hỏng. Triển khai giải pháp cấu hình cache an toàn, chuẩn hóa request/response và kiểm soát các HTTP header liên quan. Demo trước và sau khi khắc phục.
22	Xây dựng tiện ích trình duyệt cảnh báo website độc hại	Xây dựng browser extension có khả năng phân tích URL, HTTPS/TLS, domain, reputation và các đặc trưng của trang Web. Khi người dùng truy cập website có nguy cơ, hệ thống cảnh báo hoặc ngăn truy cập.